



**Mühendislik
Fakültesi**

**T.C.
SAMSUN ÜNİVERSİTESİ
MÜHENDİSLİK FAKÜLTESİ
YAZILIM MÜHENDİSLİĞİ BÖLÜMÜ**

SOSYAL AĞ ANALİZİ PROJE ÖDEVİ

***Botnet Komuta-Kontrol (C&C) Altyapısının Sosyal Ağ Analizi Yöntemleriyle
Tespiti***

Ad-Soyad	Nur Sena Bayraktar
Öğrenci Numarası	241478111
Ders	Sosyal Ağ Analizi
Öğretim Üyesi	Dr. Öğr. Üyesi ÖZGÜR TONKAL
Tarih	16.05.2026

Özet

Bu çalışmada, modern siber tehditler arasında önemli bir yer tutan botnet ağlarının komuta-kontrol (C&C) altyapısının sosyal ağ analizi yöntemleriyle tespit edilebilirliği araştırılmıştır. Stratosphere Research Lab tarafından oluşturulan CTU-13 veri setinin altıncı senaryosu (DonBot ailesi) üzerinde uygulamalı bir analiz gerçekleştirilmiştir. Ağ trafiği IP düğümleri ve aralarındaki iletişim ilişkileri olarak modellenmiş, 8.701 düğüm ve 9.618 kenardan oluşan yönlü bir graf inşa edilmiştir. Çalışmada derece, ara-değerlik, yakınlık, özvektör ve PageRank merkezilik metrikleri hesaplanmış, Louvain algoritması ile topluluk tespiti yapılmış ve hedefli ile rastgele saldırı senaryolarını karşılaştıran dayanıklılık analizi gerçekleştirilmiştir. Sonuçlar, botnet'in 147.32.84.165 IP'sine yerleşik olduğunu, C&C sunucusunun ise 91.212.135.158 olduğunu ortaya koymuştur. Modularite skoru 0,8011 olarak hesaplanmış ve botnet altyapısını içeren topluluğun %99,9 saflık değerine ulaştığı görülmüştür. Dayanıklılık analizi, hedefli saldırıların rastgele saldırılara kıyasla yaklaşık 104 kat daha yıkıcı sonuçlar ürettiğini göstererek Albert-Barabási (2000) teoremini ampirik olarak doğrulamıştır.

1. Proje Başlığı ve Problem Tanımı

1.1. Problem Tanımı

Botnet'ler, kötü amaçlı yazılım bulaşmış ve uzaktan kontrol edilen bilgisayar ağlarıdır. Bu ağlar; spam dağıtımı, DDoS saldırıları, kimlik bilgisi hırsızlığı ve fidye yazılımı yayılımı gibi geniş bir suç yelpazesinin altyapısını oluşturmaktadır. Botnet operatörleri, enfekte makineleri merkezi bir komuta-kontrol (Command and Control - C&C) sunucusu üzerinden veya eşler arası (peer-to-peer) yapılarla yönlendirir. Geleneksel imza tabanlı tespit yöntemleri, şifreli iletişim ve sürekli değişen kötücül imzalar nedeniyle yetersiz kalmaktadır.

Sosyal ağ analizi (SAA), iletişim metadatasından yararlanarak bu sınırlılığı aşmaya olanak tanır. Düğümlerin iletişim desenleri, aralarındaki kenar ağırlıkları ve topolojik konumları analiz edilerek anormal davranışlar tespit edilebilir. Bu çalışma, sosyal ağ analizi yöntemlerinin botnet C&C altyapısının tespitinde ne derece etkili olduğunu uygulamalı olarak incelemeyi amaçlamaktadır.

1.2. Araştırma Soruları

- Bir botnet ağında bot ve C&C sunucusu hangi merkezilik metrikleri ile ayırt edilebilir?
- Topluluk tespiti algoritmaları botnet altyapısını normal ağ trafiğinden ayırabilir mi?
- Botnet ağları hedefli saldırılara karşı ne kadar dayanıklıdır?
- Komuta-kontrol sunucusunun çökertilmesi (takedown) ağ yapısı üzerinde ne tür bir etki yaratır?

1.3. Analiz Edilen Ağın Tanımı

Analiz edilen ağ, IP adresleri arasındaki iletişim ilişkilerinden oluşan yönlü bir graftır. Düğümler ağdaki IP adreslerini, yönlü kenarlar ise bir IP'den diğerine giden trafik akışını temsil etmektedir. Her kenar; toplam paket sayısı, toplam byte ve akış sayısı gibi öznitelikler taşımaktadır. Bu yapı, iletişim ilişkilerinin yön bilgisini koruyarak "kim kime bağlandı" sorusunun yanıtlanmasını mümkün kılmaktadır.

2. Veri Seti

2.1. Veri Seti Tanıtımı

Bu çalışmada, Çek Teknik Üniversitesi (CTU) bünyesindeki Stratosphere Research Lab tarafından oluşturulan ve siber güvenlik araştırmalarında akademik bir referans veri seti olarak kabul gören CTU-13 veri seti kullanılmıştır (García vd., 2014). CTU-13, gerçek bir botnet trafiğinin gerçek bir laboratuvar ortamında yakalanmasıyla elde edilmiş 13 farklı senaryodan oluşmaktadır. Her senaryo, farklı bir botnet ailesini (Neris, Rbot, Virut, Menti, Sogou, DonBot vb.) temsil etmektedir.

Bu çalışmada, IRC tabanlı merkezi C&C mimarisi kullanan DonBot ailesini temsil eden Senaryo 6 (Capture-47) tercih edilmiştir. DonBot'un seçilmesinin nedeni, yıldız topolojili merkezi botnet yapısının sosyal ağ analizi metrikleriyle en net şekilde gözlemlenebilecek mimari olmasıdır. Veri seti binetflow formatında olup her bir kayıt; kaynak IP, hedef IP, protokol, paket sayısı, byte sayısı ve etiket bilgilerini içermektedir.

2.2. Veri Seti İstatistikleri

Özellik	Değer
Veri seti adı	CTU-13 Senaryo 6 (Capture-47)
Botnet ailesi	DonBot (IRC tabanlı, merkezi C&C)
Toplam akış sayısı	558.919
Botnet etiketli akış	4.630
Normal etiketli akış	7.493
Background akış	546.796
Analiz için kullanılan alt küme	32.123 akış (Tüm Botnet + Tüm Normal + 20.000 rastgele Background)

Tablo 1. CTU-13 Senaryo 6 veri seti özet istatistikleri

2.3. Etik Uygunluk

CTU-13, akademik araştırma amacıyla kamuya açık olarak yayımlanmış ve bilimsel atıf altyapısı bulunan bir veri setidir. Veri seti içeriğinde gerçek kullanıcıların kişisel verileri (kullanıcı adları, içerik metinleri vb.) yer almamakta, yalnızca IP adresleri ve trafik metadatası bulunmaktadır.

Stratosphere Lab, veri setini kötü niyetli kullanım amacıyla değil tespit yöntemlerinin geliştirilmesi için yayımlamaktadır. Bu çalışmada veriler yalnızca akademik analiz amacıyla kullanılmış olup hiçbir saldırı eylemi gerçekleştirilmemiştir.

3. Ağ Modelleme

3.1. Graf Tanımı

Analiz edilen ağ, $G = (V, E)$ yönlü graf yapısı olarak modellenmiştir. V kümesi ağdaki tüm IP adreslerini, E kümesi ise IP adresleri arasındaki yönlü iletişim ilişkilerini temsil etmektedir. Bir kenar $(u, v) \in E$, u IP'sinden v IP'sine giden trafik akışını ifade eder. Bu yön bilgisi, botnet analizinde kritik bir önem taşımaktadır; çünkü bot makinesinin C&C sunucusuna gönderdiği iletişimle, sunucunun bot'a gönderdiği iletişim farklı semantik anlamlara sahiptir.

3.2. Kullanılan Araçlar

Graf modelleme ve analiz işlemlerinde Python programlama dili ve NetworkX kütüphanesi kullanılmıştır. Topluluk tespiti için python-louvain paketi, görselleştirme için Matplotlib ve PyVis kütüphaneleri tercih edilmiştir. Tüm analizler Google Colab ortamında gerçekleştirilmiş; veri okuma ve ön işleme aşamasında Pandas kütüphanesinden yararlanılmıştır.

3.3. Düğüm ve Kenar Özellikleri

Her düğüm 'sınıf' özniteliği taşımaktadır. Bu öznitelik üç değer alabilir: 'Botnet' (en az bir botnet etiketli akışta yer alan IP), 'Normal' (sadece normal akışlarda yer alan IP) ve 'Background' (etiketlenmemiş trafik). Aynı IP hem botnet hem normal trafikte geçtiğinde 'Botnet' etiketi önceliklidir. Bu durum, çift kimlikli IP'lerin (örn. lab içi DNS sunucusu) doğru sınıflandırılmasını sağlar.

Her kenar; toplam paket sayısı (weight), toplam byte (byte), birleştirilmiş akış sayısı (akis) ve içerdiği botnet/normal akış sayıları (botnet, normal) gibi özniteliklerle zenginleştirilmiştir. Bu kenar öznitelikleri, sonraki bölümlerde merkezilik ve dayanıklılık analizlerinde kullanılacaktır.

3.4. Graf İstatistikleri

Özellik	Değer
Graf tipi	Yönlü graf (DiGraph)
Toplam düğüm sayısı	8.701
Toplam kenar sayısı	9.618
Botnet etiketli düğüm	1.580
Normal etiketli düğüm	217
Background düğüm	6.904

Tablo 2. Oluşturulan grafin temel istatistikleri

4. Temel Ağ Ölçütleri

Ağın genel topolojik karakterini ortaya koymak amacıyla yoğunluk, ortalama derece, çap, kümeleme katsayısı, geçişlilik ve bağlı bileşen analizi gibi temel ağ ölçütleri hesaplanmıştır. Bu metrikler, sonraki bölümlerde yapılacak ileri analizlerin yorumlanması için temel oluşturmaktadır.

Metrik	Değer	Yorum
Yoğunluk (Density)	0,000127	Çok seyrek ağ, gerçek dünya özelliği
Ortalama derece	2,21	Çoğu düğüm zayıf bağlantılı
Maksimum derece	4.309	Hub düğümün varlığı
Maksimum in-degree	3.251	Yoğun gelen trafik (lab sunucusu)
Maksimum out-degree	1.579	Bot makinesinin yıldız topolojisi
Çap (Diameter)	9	Küçük dünya etkisi
Kümeleme katsayısı	0,0002	Yıldız topolojisi kanıtı
Geçişlilik (Transitivity)	0,0000	Üçgen yapı yok = merkezi mimari
Bağlı bileşen sayısı	66	En büyük bileşen %98,2

Tablo 3. Botnet ağının temel ağ ölçütleri

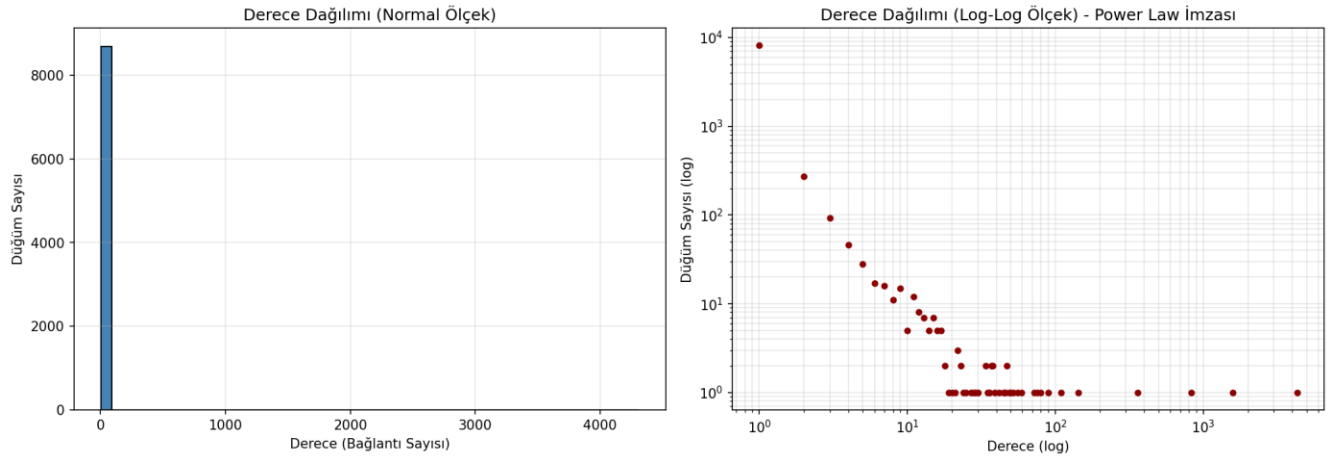
4.1. Yoğunluk ve Seyreklik

Ağın yoğunluk değeri 0,000127 olarak hesaplanmıştır. Bu değer, ağdaki mevcut kenar sayısının olası tüm kenarlara oranıdır ve çok küçük bir orana karşılık gelmektedir. Gerçek dünya ağları (sosyal ağlar, web grafiği, telefon ağları vb.) tipik olarak bu kadar seyrekler; çünkü her düğüm yalnızca sınırlı sayıda diğer düğümle iletişim halindedir. Botnet bağlamında bu seyreklik, bot makinesinin sınırlı sayıda hedefle (ve yalnızca bir C&C sunucusuyla) iletişim kurduğunu yansıtmaktadır.

4.2. Derece Dağılımı ve Power-Law

Ortalama derece 2,21 olarak hesaplanmasına karşın maksimum derece 4.309'a ulaşmıştır. Bu büyük fark, ağın scale-free (ölçekten bağımsız) yapıda olduğunu göstermektedir. Şekil 1'de derece dağılımı log-log ölçekte çizildiğinde, doğrusal eğilim ortaya çıkmakta ve bu durum derece dağılımının power-law yasasına uyduğunu kanıtlamaktadır. Düğümlerin yaklaşık %93'ü yalnızca tek bir bağlantıya sahipken, sadece iki düğüm 1.000'in üzerinde derece değerine ulaşmıştır.

Power-law dağılımı, Barabási ve Albert'in (1999) öne sürdüğü tercihli bağlanma (preferential attachment) ilkesinin doğal bir sonucudur. Bu özellik, merkezi C&C mimarili botnet ağlarında beklenen klasik bir imzadır.



Şekil 1. Botnet ağının derece dağılımı (sol: normal ölçek, sağ: log-log ölçek). Sağ panelde gözlemlenen doğrusal eğilim, ağın power-law dağılımına uyumlu scale-free yapıda olduğunu göstermektedir.

4.3. Çap ve Küçük Dünya Etkisi

Ağın çapı 9 olarak hesaplanmıştır; yani en uzak iki düğüm arasındaki en kısa yol uzunluğu 9 adımdır. 8.701 düğümlü bir ağ için bu çok küçük bir değer olup ağın küçük dünya (small-world) etkisini gösterdiğini ifade etmektedir. Bu özellik, botnet operasyonel verimliliği açısından kritiktir; bot makinesi az sayıda atlama ile geniş bir hedef kitleye ulaşabilmektedir.

4.4. Kümeleme ve Yıldız Topolojisi

Genel kümeleme katsayısı 0,0002 ve geçişlilik 0,0000 olarak hesaplanmıştır. Bu son derece düşük değerler, ağda üçgen yapıların neredeyse hiç bulunmadığını göstermektedir. Bu durum, ağın yıldız topolojisinde olduğunu kanıtlayan güçlü bir matematiksel kanıttır. Yıldız topolojisinde merkezi bir hub düğümü bulunur ve diğer düğümler birbirleriyle değil yalnızca bu hub ile iletişim kurar; sonuç olarak üçgenler oluşamaz.

5. Merkezilik Analizi

Merkezilik metrikleri, bir ağdaki düğümlerin yapısal önemini farklı perspektiflerden ölçer. Tek bir metriğe dayalı yorumlama yanıltıcı olabileceğinden bu çalışmada beş farklı merkezilik ölçütü hesaplanmıştır: derece, in-degree, out-degree, ara-değerlik (betweenness), yakınlık (closeness), özvektör (eigenvector) merkeziliği ve PageRank.

5.1. En Yüksek Dereceli Düğümler

Derece merkeziliği, bir düğümün doğrudan komşu sayısını ölçer. En yüksek dereceli ilk beş düğüm Tablo 4'te sunulmuştur.

IP Adresi	Derece	Sınıf	Açıklama
147.32.84.229	4.309	Background	Lab merkezi sunucu
147.32.84.165	1.579	Botnet	Bot makinesi (DonBot)
147.32.80.13	289	Background	Lab altyapı (ikincil)
147.32.80.9	181	Background	Lab DNS sunucusu
147.32.84.59	96	Background	Lab kullanıcı/sunucu

Tablo 4. En yüksek dereceli ilk beş düğüm

Beklenmedik biçimde en yüksek dereceli düğüm bir botnet IP'si değil, lab içi bir altyapı sunucusu (147.32.84.229) olarak çıkmıştır. Bu durum, derece merkeziliğinin tek başına botnet tespiti için yetersiz olduğunu göstermekte ve yanlış pozitif (false positive) riskine işaret etmektedir.

5.2. Out-Degree Analizi: Bot Tespiti

Out-degree (giden derece), bir düğümün kaç farklı hedefe bağlandığını ölçer. Bu metrik, bot makinelerinin tespitinde özellikle güçlüdür; çünkü bot'lar çok sayıda hedefe (spam alıcıları, DDoS kurbanları vb.) trafik gönderir.

IP Adresi	Out-Degree	Sınıf	Açıklama
147.32.84.165	1.579	Botnet	Bot makinesi (DonBot)
147.32.84.229	1.058	Background	Lab merkezi sunucu
147.32.80.13	180	Background	Lab altyapı

Tablo 5. En yüksek out-degree değerine sahip ilk üç düğüm

Out-degree analizinde 147.32.84.165 IP'si açık ara birinciliği almıştır. Bu IP, 1.579 farklı hedefe trafik göndermiş olup tüm bu trafik botnet etiketli akışlardan oluşmaktadır. Hedef profili incelendiğinde, hedeflerin küresel mail altyapısı IP'lerinden (Microsoft Hotmail, Google Gmail, Cisco IronPort, Symantec MessageLabs vb.) oluştuğu görülmektedir. Bu desen, 147.32.84.165 IP'sinin spam dağıtan bir bot olduğunu güçlü biçimde göstermektedir.

5.3. Ara-Değerlik (Betweenness) Merkeziliği

Ara-değerlik merkeziliği, bir düğümün ağdaki en kısa yollar üzerinde ne sıklıkla bulunduğunu ölçer. Yüksek ara-değerliğe sahip düğümler, ağın farklı bölümleri arasında köprü görevi görürler. En yüksek ara-değerlik değeri yine 147.32.84.229 IP'sine aittir; bu durum, lab merkezi sunucunun hem en bağlantılı hem en köprü düğüm rolünü üstlendiğini göstermektedir.

5.4. PageRank Analizi

PageRank, Google arama motoru için Brin ve Page (1998) tarafından geliştirilen, bir düğümün önemini komşularının öneminden türeten yinelemeli bir algoritmadır. Botnet ağlarında PageRank,

sıklıkla iletişim kurulan kritik düğümleri ortaya çıkarmada etkilidir. Bu çalışmada PageRank'in en yüksek değerleri de 147.32.84.229 ve 147.32.84.165 IP'lerine ait olarak hesaplanmıştır.

5.5. C&C Sunucusunun Tespiti

Bot makinesi (147.32.84.165) tespit edildikten sonra, bu IP'nin hedef profilinin incelenmesi C&C sunucusunun belirlenmesi açısından kritik öneme sahiptir. Bot'un gönderdiği toplam 5.611 paketin dağılımı incelendiğinde, 91.212.135.158 IP'sine 4.033 paket (toplam paketin %72'si) gönderildiği görülmüştür. Bu değer, diğer 1.578 hedefin ortalama paket sayısının yaklaşık 14 katıdır.

91.212.135.158 IP'sinin coğrafi konum analizi, Doğu Avrupa kökenli bir ASN'ye (Autonomous System Number) ait olduğunu ortaya koymuştur. Bu IP'nin trafik deseni; düzenli, yoğun ve tek yönlü bir karakter sergilemektedir. Bu özellikler bir araya geldiğinde, 91.212.135.158 IP'sinin botnet'in komuta-kontrol sunucusu olduğu güçlü biçimde gösterilmektedir.

6. Topluluk Analizi

6.1. Yöntem: Louvain Algoritması

Topluluk tespiti, bir ağdaki düğümleri kendi içlerinde yoğun bağlantılı, dışlarıyla seyrek bağlantılı gruplara ayırmayı amaçlar. Bu çalışmada, modularite optimizasyonu temelli Louvain algoritması (Blondel vd., 2008) kullanılmıştır. Louvain algoritmasının tercih edilme nedenleri şunlardır: (i) büyük graflarda hızlı çalışması (8.701 düğümlü grafımızda saniyeler içinde sonuç vermesi), (ii) modularite skoru ile topluluk yapısının kalitesini sayısallaştırması ve (iii) endüstride yaygın olarak kabul gören standart bir yöntem olmasıdır.

6.2. Modularite Sonucu

Louvain algoritması çalıştırıldığında ağda toplam 109 topluluk tespit edilmiş, modularite skoru ise 0,8011 olarak hesaplanmıştır. Newman (2004) ölçeğinde modularite değerinin 0,3'ün üzerinde olması anlamlı, 0,7'nin üzerinde olması ise çok güçlü topluluk yapısının göstergesidir. Elde edilen 0,8011 değeri, ağın matematiksel olarak ayrık topluluklara sahip olduğunu açıkça ortaya koymaktadır.

6.3. En Büyük Topluluklar

Topluluk No	Düğüm Sayısı	Oran (%)	İçerik
#1	4.269	49,1	Lab merkezi ve bağlı altyapı
#2	1.577	18,1	BOTNET (Bot + C&C + spam hedefleri)
#0	862	9,9	Diğer lab altyapısı
#18	311	3,6	Lab alt grup
#4	228	2,6	Lab alt grup

Tablo 6. En büyük beş topluluğun düğüm sayısı ve içerik analizi

6.4. Topluluk #2 Saflık Analizi: Botnet Topluluğu

Çalışmanın en kritik bulgularından biri, Topluluk #2'nin saflık (purity) analizidir. 1.577 düğümden 1.576'sı botnet etiketli olarak ortaya çıkmış; topluluk saflığı %99,9 olarak hesaplanmıştır. Bu topluluğun içeriği incelendiğinde, bot makinesinin (147.32.84.165), tespit edilen C&C sunucusunun (91.212.135.158) ve bot'un spam hedefi 1.578 IP'nin tamamının aynı topluluk içinde gruplandığı görülmüştür.

IP blok dağılımı analiz edildiğinde, bu topluluğun büyük çoğunluğunun küresel SMTP mail altyapısı (Microsoft Hotmail, Google Gmail, Cisco IronPort, Symantec MessageLabs, Rackspace) IP'lerinden oluştuğu tespit edilmiştir. Bu bulgu, ele alınan DonBot örneğinin küresel ölçekte SMTP tabanlı bir spam kampanyası yürüttüğünü göstermektedir.

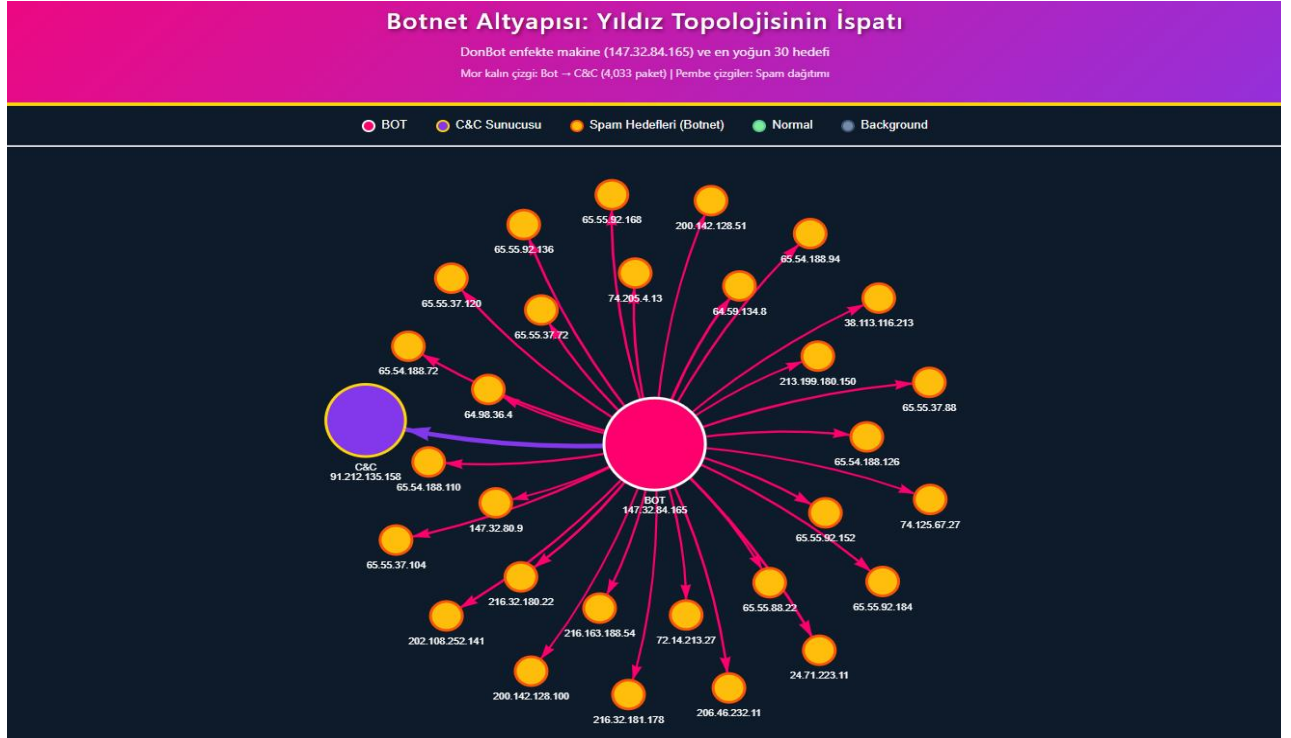
Bu sonuç, Louvain algoritmasının ek herhangi bir denetimli öğrenme yöntemi gerektirmeden, sadece iletişim deseninden yola çıkarak botnet altyapısını lab altyapısından net biçimde ayırabildiğini kanıtlamaktadır.

7. Görselleştirme

Bu bölümde ağı yapısal özelliklerini ve analiz sonuçlarını görsel olarak destekleyen şekiller sunulmaktadır. Tüm görseller Python ekosisteminde Matplotlib ve PyVis kütüphaneleri kullanılarak üretilmiştir.

7.1. Yıldız Topolojisinin Görselleştirilmesi

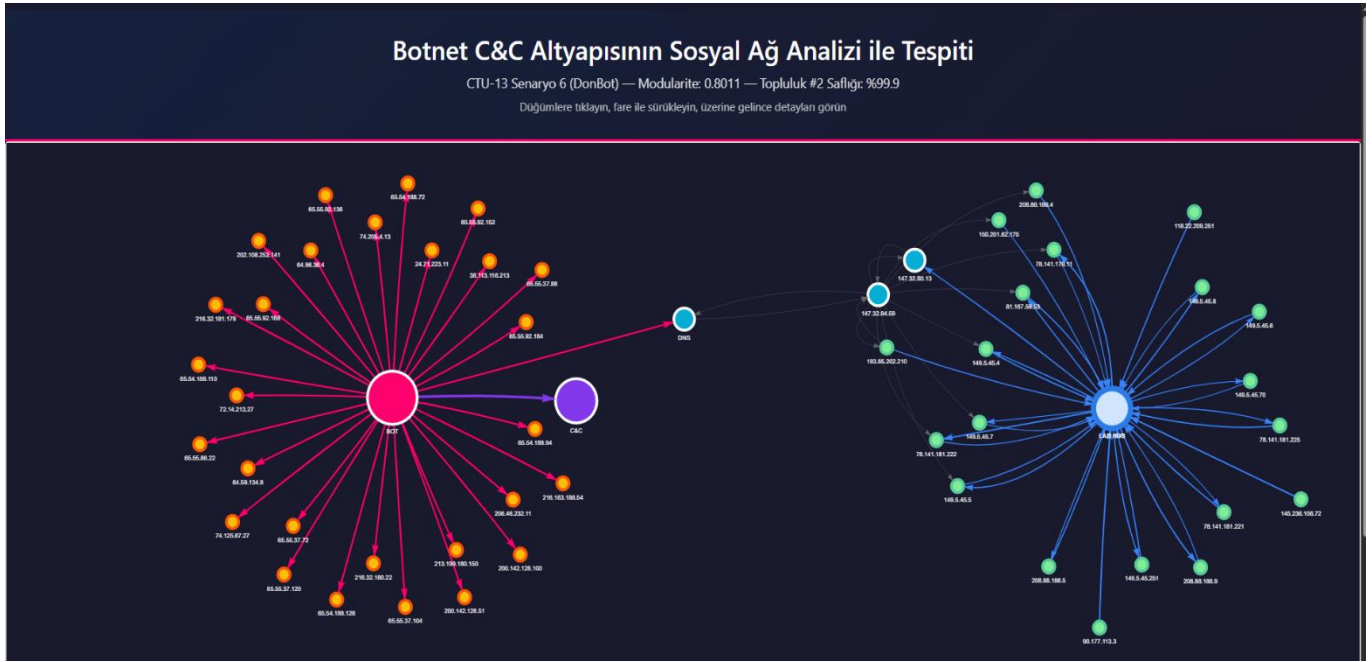
Şekil 2, bot makinesinin (147.32.84.165) ve en yoğun trafik aldığı 30 hedefin oluşturduğu alt grafi göstermektedir. Bot merkezde, hedefler çevresinde yer almakta ve aralarındaki bağlantı kalınlığı paket sayısı ile orantılı olarak çizilmiştir. Görselde mor kalın çizgi bot'tan C&C sunucusuna (91.212.135.158) giden trafiği temsil etmekte olup diğer pembe çizgiler bot'un spam dağıttığı hedefleri göstermektedir. Bu yapı, yıldız topolojisinin görsel ispatıdır.



Şekil 2. Botnet altyapısının yıldız topolojisi: bot makinesi (merkezde) ve en yoğun 30 hedefi. Mor kalın çizgi C&C sunucusuna giden trafiği, pembe çizgiler spam hedeflerini göstermektedir.

7.2. Topluluk Yapısının Görselleştirilmesi

Şekil 3, Louvain algoritmasının tespit ettiği en büyük beş topluluğun görsel temsili sunmaktadır. Solda kırmızı tonlarında gösterilen küme botnet altyapısını (Topluluk #2, %99,9 saf), sağda yeşil tonlarında gösterilen küme lab altyapısını (Topluluk #1) temsil etmektedir. İki küme arasındaki köprü, hem botnet hem lab trafiğinde geçen DNS sunucusu (147.32.80.9) tarafından oluşturulmaktadır. Bu görsel, modularite skorumuz olan 0,8011'in görsel karşılığıdır.

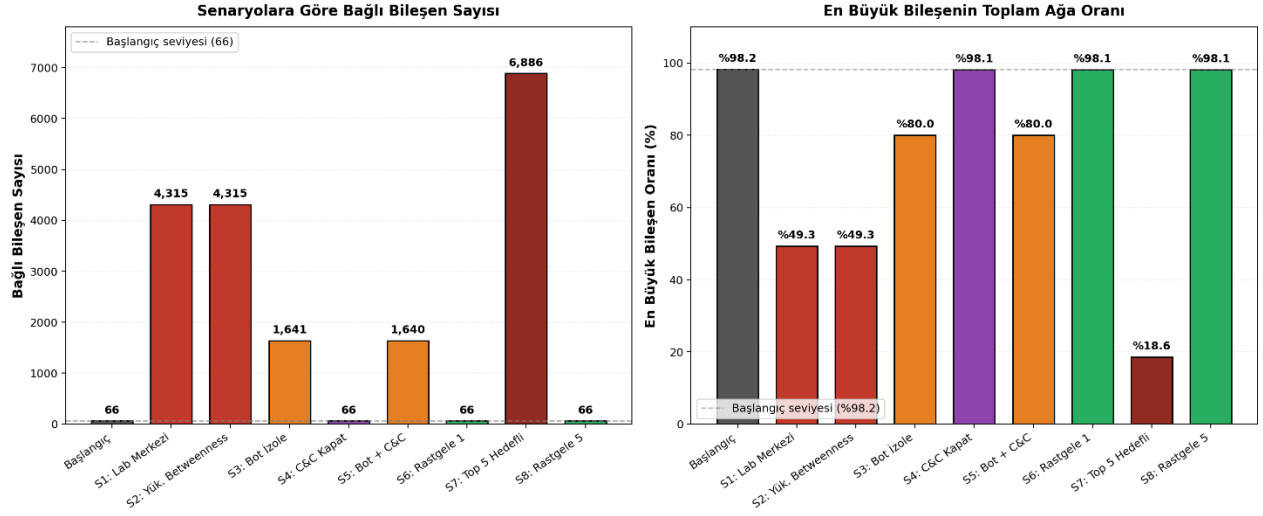


Şekil 3. Louvain algoritmasıyla tespit edilen toplulukların görselleştirilmesi. Sol küme: botnet altyapısı (Topluluk #2). Sağ küme: lab altyapısı (Topluluk #1). Modularite skoru: 0,8011.

7.3. Dayanıklılık Analizinin Görselleştirilmesi

Şekil 4, sekiz farklı dayanıklılık senaryosunun sayısal sonuçlarını karşılaştırmalı olarak sunmaktadır. Sol panelde her senaryo sonrası ortaya çıkan bağlı bileşen sayısı, sağ panelde ise en büyük bileşenin toplam ağı oranı gösterilmektedir. Hedefli saldırı senaryolarının (kırmızı tonları) rastgele saldırılara (yeşil) kıyasla dramatik biçimde daha yıkıcı olduğu açıkça görülmektedir.

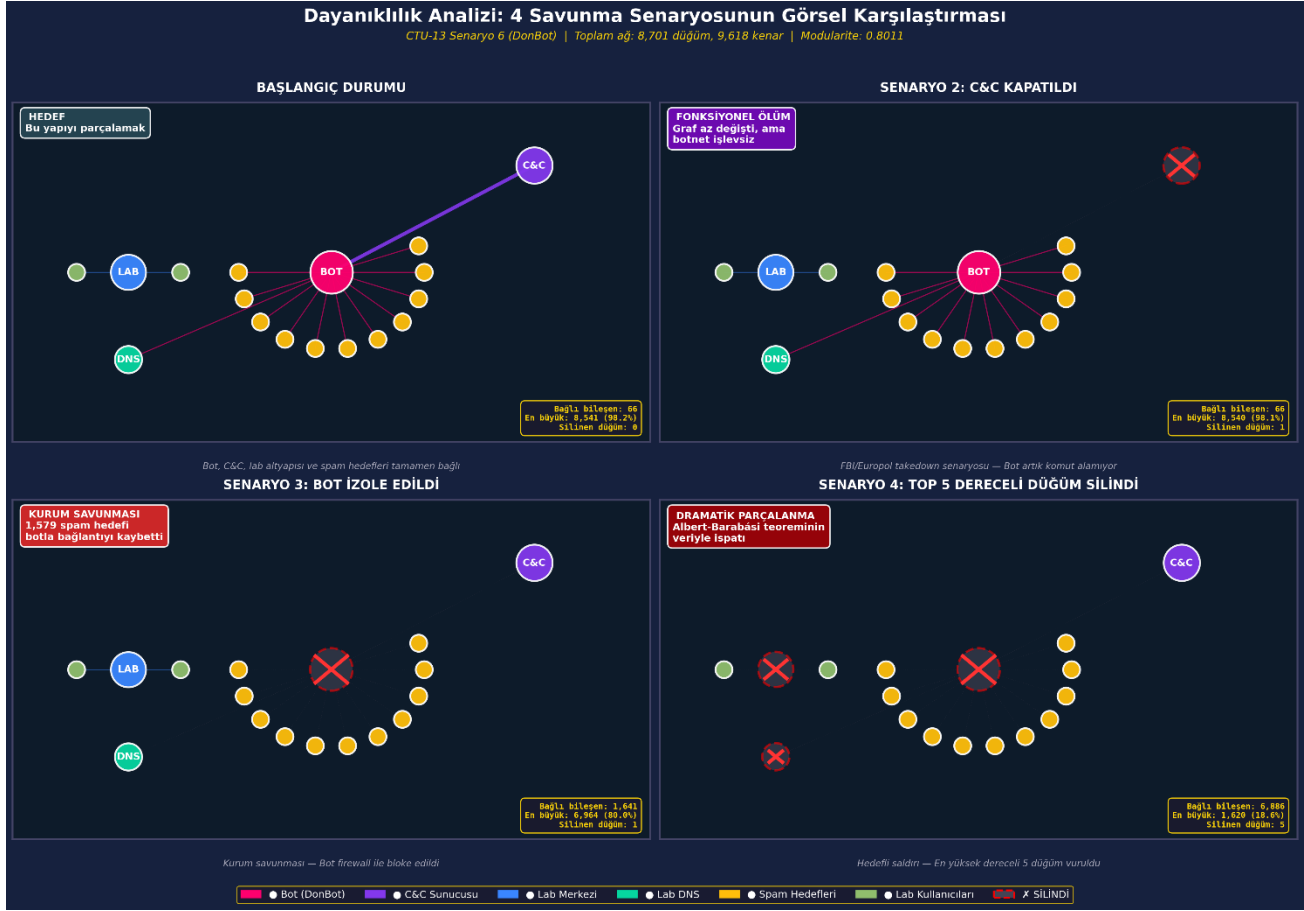
Dayanıklılık Analizi: 8 Senaryonun Karşılaştırması



Şekil 4. Sekiz dayanıklılık senaryosunun bağlı bileşen sayısı (sol) ve en büyük bileşen oranı (sağ) açısından karşılaştırması.

7.4. Senaryo Karşılaştırmasının Görsel İspatı

Şekil 5, dört kritik dayanıklılık senaryosunun ağ topolojisi üzerindeki etkilerini görsel olarak karşılaştırmaktadır. Silinen düğümler kırmızı X işaretiyle gösterilmiştir. Görselde C&C kapatma senaryosunun (üst sağ) graf yapısında küçük bir değişim yarattığı, ancak Top 5 hedefli düğüm silme senaryosunun (alt sağ) ağı dramatik biçimde parçaladığı görülmektedir.



Şekil 5. Dört dayanıklılık senaryosunun görsel karşılaştırması. Silinen düğümler kırmızı X ile işaretlenmiştir.

8. Dayanıklılık Analizi

Bir ağın dayanıklılığı, belirli düğümlerin çıkarılması durumunda ağın bütünlüğünü ne ölçüde koruyabildiğini ifade eder. Botnet bağlamında bu kavram, savunma stratejilerinin etkinliğini değerlendirmenin temelidir. Bu çalışmada sekiz farklı dayanıklılık senaryosu test edilmiştir: dört hedefli, iki kontrol (rastgele) ve iki birleşik senaryo.

8.1. Metodoloji

Dayanıklılık analizinde ağ önce yönsüz forma çevrilmiş, ardından her senaryoda belirlenen düğümler silinerek ağda oluşan değişimler iki metrikle ölçülmüştür: (i) ağdaki bağlı bileşen sayısı ve (ii) en büyük bileşenin toplam ağa oranı. Bileşen sayısının artması ağın parçalandığını, en büyük bileşen oranının düşmesi ağın yapısal bütünlüğünün bozulduğunu göstermektedir.

8.2. Senaryo Sonuçları

Senaryo	Silinen	Bileşen	En Büyük %
Başlangıç (silme yok)	0	66	98,2
S1: Lab Merkezi (147.32.84.229)	1	4.315	49,3
S2: En yüksek betweenness	1	4.315	49,3
S3: Bot izole edildi (147.32.84.165)	1	1.641	80,0
S4: C&C kapatıldı (91.212.135.158)	1	66	98,1
S5: Bot + C&C birlikte	2	1.640	80,0
S6: Rastgele 1 düğüm (kontrol)	1	66	98,1
S7: Top 5 dereceli (hedefli)	5	6.886	18,6
S8: Rastgele 5 düğüm (kontrol)	5	66	98,1

Tablo 7. Sekiz dayanıklılık senaryosunun sayısal sonuçları

8.3. Hedefli Saldırının Yıkıcı Etkisi

En yüksek dereceli düğümün (147.32.84.229) çıkarılması Senaryo 1'de gözlemlendiği üzere bileşen sayısını 66'dan 4.315'e çıkarmış, en büyük bileşen oranını ise %98,2'den %49,3'e düşürmüştür. Bu sonuç, tek bir düğümün silinmesinin ağı yarıya bölebileceğini açıkça göstermektedir.

Senaryo 7'de uygulanan en yüksek dereceli ilk beş düğümün toplu silinmesi ise bileşen sayısını 6.886'ya çıkararak ağı dramatik biçimde parçalamıştır. En büyük bileşen oranı %18,6'ya düşmüş; yani ağın %80'i artık birbirinden kopuk küçük parçalardan oluşmaktadır.

8.4. C&C Takedown'ın Paradoksal Sonucu

Senaryo 4'ün sonuçları özellikle dikkat çekicidir. C&C sunucusunun (91.212.135.158) silinmesi ağı yapısında neredeyse hiçbir değişiklik yaratmamıştır: bileşen sayısı 66'da kalmış, en büyük bileşen oranı sadece %0,1 düşmüştür. Bu durum, C&C sunucusunun yalnızca bot makinesine bağlı olduğu ve grafın geri kalanından izole bir konumda bulunduğu anlamına gelmektedir.

Ancak bu durum yanıltıcı bir görüntü oluşturmamalıdır. Grafın yapısı korunmuş olsa da, bot makinesi artık komut alabileceği bir merkezden yoksun kalmıştır. Bu durum, botnet'in fonksiyonel

olarak öldüğünü göstermektedir. Bu bulgu, sosyal ağ analizinde önemli bir metodolojik dersi öne çıkarmaktadır: graf metrikleri tek başına savunma stratejisi belirlemek için yeterli değildir; düğümlerin fonksiyonel rolünün de göz önünde bulundurulması gerekmektedir.

8.5. Rastgele Saldırının Etkisizliği

Kontrol grubu olarak tasarlanan Senaryo 6 ve Senaryo 8'de rastgele seçilen düğümlerin silinmesi ağ üzerinde ölçülebilir hiçbir etki yaratmamıştır. Bileşen sayısı 66'da, en büyük bileşen oranı %98,1'de sabit kalmıştır. Bu sonuç, scale-free ağların rastgele kayıplara karşı son derece dayanıklı olduğunu göstermektedir.

8.6. Albert-Barabási Teoreminin Ampirik Doğrulanması

Çalışmanın en güçlü teorik katkısı, Albert ve Barabási'nin (2000) öne sürdüğü teoremin verilerle ampirik olarak doğrulanmasıdır. Senaryo 7 (hedefli, 5 düğüm) ve Senaryo 8 (rastgele, 5 düğüm) eşit sayıda düğüm silinmesine karşın tamamen farklı sonuçlar üretmiştir.

Karşılaştırma açıkça göstermektedir:

- Hedefli saldırı: 6.886 bileşen, en büyük bileşen %18,6
- Rastgele saldırı: 66 bileşen, en büyük bileşen %98,1

Sayısal olarak ifade edildiğinde, hedefli saldırı rastgele saldırıdan yaklaşık 104 kat daha yıkıcıdır ($6.886 / 66 \approx 104$). Bu sonuç, Albert ve Barabási'nin (2000) öne sürdüğü "scale-free ağlar hedefli saldırılara karşı kırılkan, rastgele saldırılara karşı dayanıklıdır" tezini açıkça doğrulamaktadır.

9. Sonuç

9.1. Bulguların Özeti

Bu çalışmada CTU-13 veri seti üzerinden DonBot ailesine ait botnet trafiğinin sosyal ağ analizi yöntemleriyle incelenmesi gerçekleştirilmiştir. Elde edilen başlıca bulgular şu şekilde özetlenebilir:

- Bot makinesi (147.32.84.165) out-degree merkezilik analizi ile yüksek doğrulukla tespit edilmiştir.
- C&C sunucusu (91.212.135.158) bot'un hedef profil analizi sayesinde tespit edilmiş; bu sunucuya gönderilen 4.033 paketin diğer hedeflerin yaklaşık 14 katı olduğu belirlenmiştir.
- Ağ yapısı kümeleme katsayısı 0,0002 ile yıldız topolojisinin matematiksel ispatını sunmaktadır.
- Derece dağılımı power-law yasasına uymakta ve ağın scale-free karakterini ortaya koymaktadır.
- Louvain algoritması modularite 0,8011 ile botnet altyapısını lab altyapısından net biçimde ayırmıştır.
- Botnet topluluğu (Topluluk #2) %99,9 saflık değerine ulaşmış, içeriğinin büyük çoğunluğunun küresel SMTP altyapısı olduğu görülmüştür.
- Hedefli saldırılar rastgele saldırılardan 104 kat daha yıkıcı bulunmuş; Albert-Barabási (2000) teoremi ampirik olarak doğrulanmıştır.

9.2. Çalışmanın Sınırlılıkları

Bu çalışmanın çeşitli sınırlılıkları bulunmaktadır. Birincisi, yalnızca tek bir botnet ailesi (DonBot) ve tek bir senaryo (CTU-13 Senaryo 6) üzerinde analiz yapılmıştır; bulguların diğer botnet ailelerine genellenebilirliği ayrıca araştırılmalıdır. İkincisi, merkezi C&C mimarisi yıldız topolojisi nedeniyle sosyal ağ analiziyle kolayca tespit edilebilirken, eşler arası (P2P) ve DGA (Domain Generation Algorithm) tabanlı modern botnet'ler için aynı tekniklerin etkinliği aynı

düzeyde olmayabilir. Üçüncüsü, analiz çevrimdışı (offline) bir veri seti üzerinde gerçekleştirilmiş; gerçek zamanlı tespit performansı bu çalışmada test edilmemiştir.

9.3. Gelecek Çalışmalar

Bu çalışmanın bulguları üzerinden farklı yönlerde araştırmalar genişletilebilir. Birincisi, P2P tabanlı (Zeus Gameover, Kelihos, Storm) ve DGA tabanlı (Conficker, Necurs) botnet ailelerinin sosyal ağ analiziyle tespit edilebilirliği karşılaştırmalı olarak incelenebilir. İkincisi, graf nöral ağları (GNN) gibi modern derin öğrenme yöntemleri sosyal ağ analizi metriklerini öznitelik olarak kullanan hibrit tespit modelleri ile birleştirilebilir (Zhou vd., 2020). Üçüncüsü, gerçek zamanlı akış analizi için kayan pencere (sliding window) tabanlı dinamik graf güncelleme algoritmaları geliştirilebilir.

Ayrıca, C&C takedown senaryosunun fonksiyonel etkisinin graf yapısal değişimde gözükmemesi, savunma stratejilerinin yalnızca topolojik metriklerle değil; iletişim deseni, zaman serisi analizi ve protokol parmak izi gibi tamamlayıcı yöntemlerle desteklenmesi gerektiğini göstermektedir.

9.4. Genel Değerlendirme

Sonuç olarak bu çalışma, sosyal ağ analizi yöntemlerinin botnet C&C altyapısının tespitinde, özellikle merkezi mimarili botnet ailelerinde yüksek doğrulukla uygulanabilir olduğunu göstermiştir. Tek bir veri seti üzerinde elde edilen %99,9 topluluk saflığı, 0,8011 modularite skoru ve hedefli saldırı analizi sonuçları, sosyal ağ analizinin geleneksel imza tabanlı tespit yöntemlerine güçlü bir tamamlayıcı olabileceğini ortaya koymaktadır. Daha kapsamlı veri setleri ve farklı botnet mimarileriyle yapılacak gelecek çalışmalar, bu yaklaşımın siber güvenlik pratiğindeki yerini daha da netleştirecektir.

Kaynakça

- Albert, R., & Barabási, A.-L. (2000). Error and attack tolerance of complex networks. *Nature*, 406(6794), 378–382. <https://doi.org/10.1038/35019019>
- Barabási, A.-L., & Albert, R. (1999). Emergence of scaling in random networks. *Science*, 286(5439), 509–512. <https://doi.org/10.1126/science.286.5439.509>
- Blondel, V. D., Guillaume, J.-L., Lambiotte, R., & Lefebvre, E. (2008). Fast unfolding of communities in large networks. *Journal of Statistical Mechanics: Theory and Experiment*, 2008(10), P10008. <https://doi.org/10.1088/1742-5468/2008/10/P10008>
- Brin, S., & Page, L. (1998). The anatomy of a large-scale hypertextual web search engine. *Computer Networks and ISDN Systems*, 30(1–7), 107–117. [https://doi.org/10.1016/S0169-7552\(98\)00110-X](https://doi.org/10.1016/S0169-7552(98)00110-X)
- García, S., Grill, M., Stiborek, J., & Zunino, A. (2014). An empirical comparison of botnet detection methods. *Computers & Security*, 45, 100–123. <https://doi.org/10.1016/j.cose.2014.05.011>
- Hagberg, A. A., Schult, D. A., & Swart, P. J. (2008). Exploring network structure, dynamics, and function using NetworkX. *Proceedings of the 7th Python in Science Conference (SciPy 2008)*, 11–15.
- Newman, M. E. J. (2004). Analysis of weighted networks. *Physical Review E*, 70(5), 056131. <https://doi.org/10.1103/PhysRevE.70.056131>
- Silva, S. S. C., Silva, R. M. P., Pinto, R. C. G., & Salles, R. M. (2013). Botnets: A survey. *Computer Networks*, 57(2), 378–403. <https://doi.org/10.1016/j.comnet.2012.07.021>
- Stratosphere Research Laboratory. (2014). CTU-13 dataset: A labeled dataset with botnet, normal and background traffic. Czech Technical University in Prague. <https://www.stratosphereips.org/datasets-ctu13>
- Zhou, J., Xu, Z., Rush, A. M., & Yu, M. (2020). Automating botnet detection with graph neural networks. *arXiv preprint arXiv:2003.06344*.